

# V2 Roadmap

## Product & Hardening Plan — audited against the live codebase

VERSION 2.2 · JULY 2026 · INCORPORATES THE 2026-07-05 FOUR-TRACK SECURITY AUDIT; S2 FULL-FIX FOLDED INTO THE TIER 0 SMART-ACCOUNT MIGRATION (2026-07-20)

Novi Corpus gives AI agents a real legal body: a Wyoming DAO LLC wrapped around a governed on-chain USDC treasury on Arc, with a human always holding the brake. V1 proved the full agent lifecycle end-to-end on testnet. This document lists what a production-grade V2 requires, ordered by relevance, and every item has been verified against the current code by a four-track audit (contracts, backend, payments/custody, product/infra).

**Audit outcome.** The roadmap's direction is sound, but the audit (1) surfaced **five security gaps the original roadmap did not name** — now the top-priority "Security Foundations" tier below; (2) found several items **already implemented** (the code had moved ahead of the backlog); and (3) **corrected ~10 items** that were mischaracterized or whose naive fix would introduce a regression. Verdict tags appear on each item.

*Scope note: the critical items are not live exploits on today's single-tenant testnet deployment — they become critical in the multi-tenant BYOA product this roadmap describes.*

- Foundational (before real money / mainnet)

● Robustness & scale

● Product & polish

|

CRITICAL

CONFIRMED

DONE
- RECHARACTERIZED

RISK-IN-FIX



These outrank the flagship bets. They are the concrete failure modes an attacker (or a buggy tenant) reaches in the multi-tenant product; several are one-line trust assumptions today.

### S1 Unbounded `fund_treasury` drain of the shared platform wallet

CRITICAL · NEW

The MCP `fund_treasury` tool moves USDC from the platform manager wallet into the caller's treasury, gated only by the spend capability + ownership — with **no per-call cap, no per-tenant quota, and no ceiling on the amount**. Any tenant with a spend key could pull the platform wallet's balance into their own treasury, then spend it out. **Fix:** gate behind a distinct admin/provision capability with a hard per-tenant funded ceiling — or require tenants to fund from their own external wallet. (`run_job` already got these caps; this is the same class, uncapped.)

### S2 x402 payments enforce the same rules as direct spend, but in software — standing float sat beyond guardian clawback

CRITICAL

Confirmed independently by two auditors, then corrected against the live code in the 2026-07-20 design review: x402 payments apply the **same** allowlist, per-tx-cap, threshold and pause rules as direct `spend()` — enforced in software (`evaluatePolicy`, re-checked before every payment against fresh on-chain reads), not contract-guaranteed the way `spend()` is. The genuine gap: `fundOperator` is **allowlist-exempt on-chain** and has **no on-chain per-tx cap** (only a period cap) before it moves funds to the operator's hot EOA/pocket/Gateway — so once funded, that standing float sat beyond the guardian's `emergencyWithdraw/pause` reach until spent. Same rules — contract-guaranteed for direct spends, software-enforced for x402; the on-chain-guaranteed x402 bounds are **period cap + pause + legal status + the standing-float ceiling** (below). **Fix — two-part plan (decided 2026-07-20):** the **full close is an explicit acceptance criterion of the Tier 0 smart-account migration (#2)** — a policy module on the operator smart-account enforcing allowlist + per-tx cap on its own payments, or treasury-direct signing (#6). It is **not** a free side effect of swapping wallet types; a plain wallet-type swap leaves S2 open. **Interim shipped (this item, 2026-07-20):** a hard `MAX_POCKET_FLOAT_USDC` ceiling (default 1.00 USDC) bounds operator+pocket+Gateway standing float at the funding choke point, a per-agent lock closes the TOCTOU window, an on-chain legal-status re-check was added to the off-chain gate, and the docs/UI now describe the real on-chain-vs-software split instead of implying x402 is ungoverned — no new contract, no unverified-Arc dependency.

### S3 A single `POCKET_MASTER_SEED` custodies every agent's pocket key

HIGH · NEW

All pocket signing keys are derived in-process from one env seed. **Why it matters:** one leak = the ability to sign x402 and drain every agent's Gateway float at once — the broadest-scope key in the system, and not covered by the roadmap's key-separation item. **Fix:** per-agent key isolation (KMS/Turnkey-derived), never a shared master seed in plaintext env.

### S4 `PLATFORM_PRIVATE_KEY` is one raw hot key doing five jobs

HIGH

It is the manager and the factory owner and the upgrade-beacon owner and the fallback for customer / job-client / evaluator / x402 payout. **Why it matters:** a single leak lets an attacker mint entities, re-bind agent wallets, upgrade every manager, and drain the manager wallet. **Fix:** role-separate the keys (distinct factory-owner and beacon-owner, ideally multisig) and move signing to a KMS. This sharpens the roadmap's "role-separated keys" and "beacon → multisig" items into one containment effort.

### S5 No aggregate outflow ceiling, no rate-limiting, no observability

HIGH

Spend caps are *per-tenant* over a *shared* platform funding wallet, so N tenants collectively can exceed any intended platform outflow; there is no rate-limiting on any route (`auth` / `nonce` / `metadata` are unthrottled), the `auth_nonces` table grows unbounded (storage DoS), session JWTs have no revocation, and there are no metrics/alerts on a money-custody platform. **Fix:** a platform-wide daily outflow cap + alerting, request rate-limiting, a nonce-TTL sweep, and JWT revocation.

### S6 Contract asymmetries: no `MAX_CAP` ; `LegalManager.sweep` to any address

CONFIRMED · NEW

period is bounded by `MAX_POLICY_PERIOD` but cap has no upper bound, so the guardian veto is the only backstop against an unlimited-cap escalation; and `LegalManager.sweep` sends residual assets to a caller-supplied address (vs the treasury's fixed payout sink). **Why it matters:** both are deliberate today but should be documented and bounded before multi-tenant production.

**1 A real multi-party economic loop**

CONFIRMED

Today the platform impersonates every counterparty — it funds job escrow, plays the evaluator, and stands in as the paying customer. **Why it matters:** the line between a self-contained demo and an actual marketplace with real clients, independent evaluators, and paying customers.

EFFORT: L

UNLOCKS: REAL REVENUE

**2 EOA → Circle smart-account migration (ERC-4337 + Gas Station)**

RECHARACTERIZED

Move each agent's operator/pocket to Circle smart accounts with sponsored gas and atomic batched UserOps. **Why it matters:** removes the gas seeder, the Arc estimate-gas footgun (#33), and the bridge race in one move.

🔍 **Audit:** genuine complexity win on the gas plumbing, but it is an *invariant-neutral signing swap* — a Circle-controlled SCA is the same "bounded hot wallet" trust as today and does *not* by itself close the allowlist/cap gap (S2). Gated on unverified Circle SCA/Gas-Station/ERC-1271 support on Arc.

🔍 **Carries the S2 close (decided 2026-07-20):** this migration MUST enforce the allowlist + per-tx cap on the new operator smart-account's own payments (a policy module), or adopt treasury-direct signing (#6) — **closing S2 is an explicit acceptance criterion of this item, not an optional side effect.** Until it ships, S2 runs a bounded-risk interim (see Tier S · S2).

**3 Custody choice: Circle Dev-Controlled + Agent Wallets (Model B)**

RECHARACTERIZED

Offer Circle Dev-Controlled Wallets as the Model-A operator beside Turnkey, and Agent Wallets for the self-sovereign Model B. **Why it matters:** serves both custody audiences and completes the "full Circle stack" story.

🔍 **Audit:** DevC-as-operator is confirmed feasible on Arc and invariant-neutral. Agent Wallets remain gated on unverified Arc binding + a programmatic hook; Model B must still install the agent key as the treasury *operator* (bounded by cap/pause) or it breaks the guardian brake. The "the custody field already exists" claim was not found in the backend — verify.

**4 Circle policy engine as defense-in-depth**

CONFIRMED · CONDITIONAL

Enforce spending rules Circle-side in addition to the on-chain caps. **Why it matters:** a strong extra guardrail if it bounds even a compromised backend.

🔍 **Audit:** "bounds a compromised backend" is true *only if* policy changes are gated to a principal the backend does not hold (separate Console/admin credential). Today the same process holds the pocket seed and the signer, so off-chain caps give *zero* protection against a compromised backend — the only such bound is on-chain.

**5 Trust-minimized, always-on Payment Authority**

CONFIRMED

The per-spend policy checker is trusted, centralized, and a single point of failure (and of compromise, since it also holds the pocket seed and reaches the signer). Add HA/liveness, an auditable ledger, and a verifiable execution path (TEE / ZK / on-chain checkpoints). **Why it matters:** the governor of a governed treasury shouldn't be unverifiable or fragile.

**6 Treasury-direct x402 signing (EIP-1271 / ERC-7598)**

RISK-IN-FIX

Let the treasury contract sign its own x402 authorizations, removing the hot operator EOA. **Why it matters:** it is the *only* item that structurally closes S2 — payment happens from governed funds, so caps/allowlist/pause apply to the real payment.

🔍 **Audit:** as naively described it would *bypass every on-chain cap* — EIP-3009 settles at the token contract (not via `spend()`), and a `view isValidSignature` cannot update the rolling-cap state atomically. It needs a *stateful* settlement design (nonce-gated entryptoint or a debiting 4337 validator), plus a redeployed treasury (collides with the immutable-treasury migration item). Treat as design work, not a drop-in.

🔍 **This is the mechanism that satisfies #2's S2 acceptance criterion** — the operator smart-account can host it (ERC-1271) or run a policy-module equivalent; until it ships, S2 runs a bounded interim (Tier S · S2).

**7 Agent-to-agent payments**

RECHARACTERIZED

Two governed agents transacting directly.

🔍 **Audit:** needs *no* new contract — `spend()` already pays any address, and the seller already sets `payTo` to the payee's governed treasury. Much of the plumbing exists; the real work is governance (enforceably allowlisting counterparties), and it inherits S2.

## 8 x401 controller identity & KYC CONFIRMED

Adopt x401 (Proof + Circle) as the onboarding controller-verification step: IAL2 KYC and a verifiable "who's behind this agent" credential. **Why it matters:** satisfies the mandatory natural-person controller gate and completes the agentic-stack story. Consume from the issuer — do not build.



## SMART CONTRACTS &amp; ON-CHAIN SECURITY

## 1 Beacon owner → multisig / timelock

CONFIRMED

A single testnet EOA owns the upgrade beacon for every agent's manager contract. **Why it matters:** a compromised key could upgrade all managers at once.

🔍 **Audit:** real, but fund-blast-radius is narrower than "drain all agents" — the treasury is a separate immutable contract and emergencyWithdraw still works. Pair this with separating the *factory-owner* key (same EOA today) — see S4.

## 2 Policy nonce &amp; signature-replay protection

RECHARACTERIZED

Replay protection for on-chain policy actions.

🔍 **Audit:** a *phantom* for the current contracts — the treasury policy path is `msg.sender/onlyManager`-authenticated with no signatures to replay. The real half is the ERC-8004 AgentWalletSet binding, which lives in the *canonical registry*, *not our code*; mitigated by short deadlines. Only becomes an owned concern if a meta-tx/EIP-1271 path is added (see Tier 0 #6).

## 3 Guardian multisig + role rotation

CONFIRMED

Guardian and manager are single immutable keys with no rotation path. **Why it matters:** a lost manager key is unrecoverable in-place; for the treasury it means a full redeploy (it's immutable and the factory can't re-point an agent to a new treasury).

## 4 Live-registry fork tests + professional external audit

RECHARACTERIZED

Commission a manual external audit and add fork tests of the real register/re-bind/8183 paths.

🔍 **Audit:** "deployed contracts are mocks" is *wrong* — the live Arc deployment uses the real canonical registries; the mocks are CI-only. The genuine gap is *CI fork coverage* of the real paths, plus the still-needed external audit (correctly ●).

## 5 Pre-mainnet build gates + reputation wiring

CONFIRMED

via\_ir bytecode re-review, a Mythril run, pinning the pragma to 0.8.24, and wiring the ERC-8183 reputation interfaces (interface-only stubs today). **Why it matters:** closes the known pre-production checklist. Keep any reputation writes off the treasury spend path (new external-call surface).

## BACKEND CORRECTNESS &amp; SAFETY

## 6 Onboarding create → persist double-mint window

DONE

A crash between mint and persistence re-minting a second agentId.

🔍 **Audit:** *largely fixed already* — the saga splits broadcast/confirm, persists the tx hash first, and adopts the in-flight tx on resume. Only a razor-thin residual remains. Drop from Tier 1; the backlog doc had lagged the code.

## 7 Onboarding concurrency: key-claim lock

DONE

Two concurrent onboarding calls both minting.

🔍 **Audit:** *fixed* — an atomic `claimKey` (INSERT ON CONFLICT DO NOTHING) is taken before any side effect; the loser gets 409. Residual: the `fund()` re-entry guard is per-process in-memory, so flag it before scaling to multiple app processes.

## 8 Spec-hash idempotency + monotonic status

LATENT

Bind a spec hash to the key so a resumed/funded record can't drift; guard against backward status writes. **Why it matters:** both are real hardening.

🔍 **Audit:** latent, *not currently exploitable* — a changed-spec re-run hits the key-claim 409, and no caller writes status backward. Low priority.

## 9 Role-separated keys / KMS

CONFIRMED · HIGH

One PLATFORM\_PRIVATE\_KEY is manager + factory owner + beacon owner + fallback for customer / job-client / evaluator / x402 payout. **Why it matters:** single total-compromise point. This is Tier S #4 — the highest-value key to contain.

🔍 **Audit:** supersedes the roadmap's "make Turnkey the default signer" item — Turnkey is *already* the operator default; the exposure is this raw platform/manager key, not the operator.

## 10 Capability-model split + earn quota CONFIRMED · HIGH

The spend rung gates *both* third-party payment and provisioning (onboard\_agent, fund\_treasury). **Why it matters:** this is the direct enabler of the S1 drain — split off an admin/provision rung. (run\_job earn is already budget/inflight-capped.)

---

## 11 SSRF pinning, auth hardening, metadata & nonce-store limits CONFIRMED

Pin the SSRF fetch to the validated IP (documented DNS-rebinding TOCTOU); add SIWE rate-limiting, httpOnly cookie sessions, and nonce burn-on-attempt; add a nonce-TTL sweep and JWT revocation; cache the metadata route to remove sync file reads. **Why it matters:** the exposed surfaces an attacker probes first. (*Replay-nonce durability is lower priority — the on-chain single-use nonce is the real double-settle backstop; the in-memory set only guards the demo quote.*)

## Tier 2 Robustness & scale

Production readiness 

### 1 SQLite → Postgres CONFIRMED

Every store is a single-file, single-process SQLite DB (with an acknowledged idempotency race). **Why it matters:** multi-instance HA and concurrent writers are impossible until this moves; note several in-memory guards (funding re-entry, replay set) also assume one process.

### 2 Durable document storage + metadata backfill CONFIRMED

Metadata bytes still live on local disk (the public URL is now HTTPS, but storage is local); move to S3 / Vercel Blob / IPFS and backfill the legacy demo agents whose URIs are still file://. **Why it matters:** the metadata URI is baked on-chain permanently.

### 3 Real job worker CONFIRMED

The worker returns a hardcoded string. **Why it matters:** replace with a real agent/LLM worker producing content-addressed deliverables.

🚩 **Audit:** the companion "read jobld from an event" idea is *infeasible* — the ERC-8183 job contract emits no JobCreated event, which is exactly why the code reads the simulate return. The real concurrency fix is a contract-side event or a post-mine ownership re-read.

### 4 Aggregate outflow ceiling, observability & alerting CONFIRMED · ELEVATED

A platform-wide daily outflow cap, plus structured logs, metrics, and alerts on treasury balances / failed jobs / gas outflow. **Why it matters:** promoted by the audit — this is the amplifier behind S1/S5 and the platform currently custodies money with no operational visibility.

### 5 Withdrawable Gateway balance CONFIRMED

Pocket float is kept near zero because the SDK wrapper can't withdraw the Gateway-held balance. **Why it matters:** beyond capital efficiency, any non-zero float sits outside guardian reach (S2) — so JIT float minimization is currently a security mitigation, not just an optimization. Withdrawability is a Gateway-SDK capability, orthogonal to the smart-account work.

### 6 Cleanup: de-scope `retryOnStaleBalance` RISK-IN-FIX

A retry loop on the funding bridge.

🚩 **Audit:** do *not* blanket-remove — it guards a *different* failure than #33 fixed (RPC read-lag after a write, not the estimate-gas revert), and the deposit path has no preceding poll. Safe to trim only the redundant forward-path retry after confirming the deposit path's read-lag is otherwise covered.

**1 Payments-history UI** CONFIRMED ●

A GET /entities/:id/payments endpoint + dashboard card reading the ledger. **Why it matters:** closes the gap between what the agent did and what the dashboard shows.

🔍 **Audit:** must enforce *both* the entity\_key filter and the ownerTenantId ownership check (mirror the runs route) — entity\_key alone is caller-supplied. Ledger rows carry no secret/hash, so exposure risk is otherwise low.

**2 Real x402 seller, real datasets, expanded MCP tools** CONFIRMED ●

Replace the flag-gated demo quote and synthetic datasets; add tools like authorize\_payment / agent\_ask / job-reputation.

🔍 **Audit:** any new fund-moving tool must reproduce the existing gate triad — hasCapability + entityInScope + ownerTenantId, with scope closed over per connection (never read from a tool arg). This is the single most important invariant to preserve on expansion.

**3 In-UI "run the agent" trigger + explicit sweep tool** CONFIRMED · CAUTION ●

An in-dashboard run trigger / autonomous runner, and an explicit sweep\_earnings tool instead of the always-on flag. **Why it matters:** gives the human legible control.

🔍 **Audit:** a UI trigger authorizes autonomous spend from a browser session — require the same tenant-ownership check as every entity route, an explicit per-run budget echoed to the user, and no escalation beyond the treasury leash. Don't let it bypass the capability model.

**4 Onboarding & developer-experience polish** MOSTLY CONFIRMED ●

Server-persist onboarding progress (only localStorage today), live claim-status polling on bootstrap, a generated OpenAPI client from the Zod AgentSpec (removes a hand-written drift point), an active-nav-state fix, and governance.default({}) in the agent-spec (missing the wrapper its siblings have). **Why it matters:** smooths first-run and integration.

🔍 **Audit:** the "connection copy label" sub-item appears *already implemented* — drop unless a specific wording change is intended.

The audit confirmed this track is core to a "legal body," not gold-plating: today `ein/formationDate` are stubbed and the on-chain dissolution lifecycle exists but is unsurfaced. A legal-body product without real filing/EIN/OA/KYC is a technical shell around a legal placeholder.

### 1 Real entity formation CONFIRMED

Actual Wyoming DAO LLC filing, a real EIN, crypto-friendly banking, and legally-reviewed operating-agreement documents.

### 2 KYC / user-of-record + OA-to-chain mapping CONFIRMED

Confirm the KYC "user-of-record" model (a natural-person controller is already established as mandatory), and settle the OA-clause → on-chain mapping, the Wyoming submission format, and upgradeability disclosure.

### 3 Entity lifecycle & compliance monitoring CONFIRMED

Surface the existing dissolution/wind-up lifecycle in-product, plus the dissociation mechanic, inter-entity contracting, and automated compliance (annual filings, sanctions screening, SAR).

### 4 Multi-jurisdiction + fiat rails CONFIRMED

A second jurisdiction (e.g. Marshall Islands) with unified UX, and a fiat on/off-ramp via Circle Mint. **Why it matters:** broadens users and connects the treasury to traditional finance.

## AUDIT CORRECTIONS AT A GLANCE

| ITEM                                         | VERDICT         | WHAT CHANGED                                                                                             |
|----------------------------------------------|-----------------|----------------------------------------------------------------------------------------------------------|
| Onboarding double-mint window                | Done            | Already fixed (broadcast/confirm split + resume-adopt); thin residual only.                              |
| Key-claim concurrency lock                   | Done            | Already fixed (atomic <code>claimKey</code> ).                                                           |
| Connection copy label · shadowing-locals nit | Done            | Already implemented / already renamed.                                                                   |
| Policy nonce                                 | Recharacterized | Phantom for current contracts — no signature path in the treasury policy to replay.                      |
| "Deployed contracts are mocks"               | Recharacterized | Live deploy uses the real canonical registries; the gap is CI fork coverage.                             |
| "Make Turnkey the default signer"            | Recharacterized | Turnkey is already the operator default; the raw-key exposure is <code>PLATFORM_PRIVATE_KEY</code> (S4). |
| Agent-to-agent payments                      | Recharacterized | No contract work needed — <code>spend()</code> already pays any address.                                 |
| "jobId from event, not simulate"             | Recharacterized | Infeasible — the job contract emits no event; <code>simulate-return</code> is correct.                   |
| Treasury-direct x402 signing                 | Risk-in-fix     | Naive EIP-1271 bypasses all on-chain caps; needs a stateful settlement design.                           |
| De-scope <code>retryOnStaleBalance</code>    | Risk-in-fix     | Guards RPC read-lag, not the #33 revert; partial de-scope only.                                          |

## RECOMMENDED SEQUENCING — POST-AUDIT ORDER

1. **S1 + capability split** — cap/gate `fund_treasury` behind an admin capability (same fix). The one item that is a genuine authorization bug.
2. **Contain the hot-key blast radius** — split `PLATFORM_PRIVATE_KEY`, separate factory/beacon owners (S4), per-agent pocket keys (S3).
3. **Close the on-chain governance gap (S2)** — the real motivation behind treasury-direct signing / removing the hot-EOA path.
4. **Amplifiers (S5)** — aggregate outflow ceiling + rate-limiting + observability.
5. **Contract pre-mainnet gates** — beacon → multisig, guardian rotation, fork tests, external audit.
6. **Then** the product-defining bets (multi-party loop, custody choices, x401) and product/UX/legal tracks.

**Sources & method.** Compiled from the repository design specs/plans (`back/docs/design/*`, `back/docs/plans/*`), audit notes (`back/docs/audit/*`), the deferred-items ledger (`back/docs/V2_HARDENING_BACKLOG.md`), and `back/docs/SPEC.md`. Every item was then verified against the live code by a four-track audit (contracts, backend, payments/custody, product/infra), read-only, on 2026-07-05. Two independent tracks corroborated finding S2. Severity legend: ● correctness / safety · ● robustness / ops · ● cleanup / polish.